

GUARROMAN.LOCAL

Expediente de Adecuación Normativa

ENS · ISO/IEC 27001 · RGPD

Ayuntamiento de Guarromán + Casa de la Cultura

Campo	Detalle
Elaborado por	Quique Cebrián — Técnico en Sistemas de Tecnologías de la Información
Responsable del Sistema	Jorge Cortés — Técnico en Sistemas TI
Responsable de Seguridad	Quique Cebrián — Técnico TI (rol delegado por la Corporación Municipal)
Responsable de la Información	Alcalde / Corporación Municipal
Clasificación	CONFIDENCIAL
Versión	1.0 — Mayo 2026
Marco normativo	RD 311/2022 (ENS) · ISO/IEC 27001:2022 · RGPD (UE) 2016/679
Nota aclaratoria	Los roles ENS están simplificados al tratarse de un entorno de prácticas académicas. En un ayuntamiento real cada figura recaería en personas o unidades diferenciadas.

0. Nota Previa — Figuras de Responsabilidad ENS

El Esquema Nacional de Seguridad (RD 311/2022, Art. 11) exige la diferenciación formal de tres roles de responsabilidad sobre los sistemas de información. En un Ayuntamiento real cada figura recaería en personas o unidades distintas. En el presente entorno de prácticas quedan asignadas de la siguiente manera:

Figura ENS	Definición	Asignación en GUARROMAN.LOCAL
Responsable de la Información	Determina los requisitos de seguridad de la información tratada. Establece los niveles de las dimensiones DICAT.	Alcalde / Corporación Municipal del Ayuntamiento de Guarromán
Responsable del Sistema	Se encarga de la operación, mantenimiento y seguridad del sistema de información en el día a día.	Jorge Cortés — Técnico en Sistemas TI
Responsable de Seguridad	Determina las decisiones sobre seguridad. Elabora y supervisa el plan de adecuación al ENS. Puede coincidir con el Responsable del Sistema en entidades pequeñas.	Quique Cebrián — Técnico en Sistemas TI (por delegación de la Corporación)

Esta simplificación es habitual y está prevista en el propio ENS para entidades de pequeño tamaño como los municipios rurales, donde los recursos humanos disponibles no permiten la separación estricta de funciones.

1. Objeto y Alcance del Expediente

1.1 Objeto

El presente expediente tiene por objeto documentar el estado de adecuación de los sistemas de información del Ayuntamiento de Guarromán al marco normativo de seguridad aplicable, identificar las brechas existentes respecto a los requisitos obligatorios, y establecer un plan de implementación con plazos definidos para su resolución.

Este documento no es un informe técnico de infraestructura, sino un expediente normativo que toma como punto de partida la infraestructura existente de GUARROMAN.LOCAL para evaluar su grado de cumplimiento legal.

1.2 Ámbito de Aplicación

El expediente abarca la totalidad de los sistemas de información del Ayuntamiento de Guarromán, incluyendo:

- Sede principal del Ayuntamiento (Guarromán): infraestructura JSBach, VLANs 2-6, WiFi 10.1.99.0/24, Active Directory GUARROMAN.LOCAL, SOC (Wazuh + Suricata), DMZ (Apache2/WordPress).
- Sede secundaria Casa de la Cultura: infraestructura JSBach, VLANs 15 y 16, WiFi CC, acceso al AD del Ayuntamiento mediante VPN WireGuard.
- Interconexión entre sedes mediante túnel VPN WireGuard cifrado.
- Todos los sistemas que traten datos personales de ciudadanos, empleados municipales o datos de gestión administrativa.

1.3 Marco Normativo Aplicable

El Ayuntamiento de Guarromán, en su condición de Administración Local, está sujeto con carácter obligatorio a la siguiente normativa:

Norma	Referencia legal	Obligatoriedad	Objeto
Esquema Nacional de Seguridad (ENS)	RD 311/2022, de 3 de mayo	OBLIGATORIA	Seguridad de los sistemas de información de la Administración Pública
Reglamento General de Protección de Datos (RGPD)	Reglamento (UE) 2016/679	OBLIGATORIA	Protección de datos personales de ciudadanos
Ley Orgánica de Protección de Datos (LOPDGDD)	LO 3/2018, de 5 de diciembre	OBLIGATORIA	Adaptación del RGPD al ordenamiento jurídico español
ISO/IEC 27001:2022	Estándar internacional UNE-ISO/IEC 27001	REFERENCIA	Marco de buenas prácticas incorporado metodológicamente por el ENS
Instrucciones Técnicas de Seguridad (ITS)	CCN — Desarrollo del ENS	OBLIGATORIA	Concreción técnica de los requisitos ENS: notificación, auditoría, conformidad

2. Categorización del Sistema de Información

Conforme al Anexo I del RD 311/2022 y a la Instrucción Técnica de Seguridad de Categorización de Sistemas, la determinación de la categoría de seguridad es el punto de partida obligatorio de todo proceso de adecuación al ENS. La categoría se obtiene evaluando el impacto potencial de un incidente de seguridad sobre cada una de las cinco dimensiones de seguridad (DICAT).

2.1 Dimensiones de Seguridad — Análisis de Impacto

Dimensión	Descripción	Nivel	Justificación para GUARROMAN.LOCAL
D — Disponibilidad	Acceso y uso de la información y los sistemas cuando se requiera.	MEDIO	Los servicios electrónicos municipales (padrón, licencias, sede electrónica) son esenciales para ciudadanos. Una interrupción prolongada causaría perjuicio grave pero no catastrófico.
I — Integridad	Exactitud y completitud de la información. Ausencia de modificaciones no autorizadas.	MEDIO	Los datos de expedientes administrativos, contabilidad y padrón municipal deben ser exactos. Una modificación no autorizada podría invalidar actos administrativos.
C — Confidencialidad	Solo acceden a la información las personas autorizadas.	MEDIO	El Ayuntamiento trata datos personales de categorías especiales (padrón, servicios sociales). Su exposición causaría perjuicio grave a los afectados.
A — Autenticidad	La identidad de usuarios y sistemas está verificada.	MEDIO	Los trámites electrónicos y notificaciones requieren identidad verificada. La suplantación de identidad en actos administrativos tendría consecuencias jurídicas graves.
T — Trazabilidad	Las actuaciones sobre la información quedan registradas.	MEDIO	El registro de accesos y modificaciones en expedientes es obligatorio para la responsabilidad administrativa y la auditoría.

CONCLUSIÓN DE CATEGORIZACIÓN: CATEGORÍA MEDIA. Al menos una dimensión alcanza nivel MEDIO y ninguna alcanza nivel ALTO. Conforme al Art. 40 del RD 311/2022, los sistemas de categoría MEDIA requieren la aplicación del conjunto de medidas de seguridad del Anexo II correspondientes a dicha categoría, auditoría externa cada dos años y certificación de conformidad por entidad acreditada ante ENAC.

2.2 Implicaciones de la Categoría Media

- Aplicación de todas las medidas del Anexo II del ENS para categoría MEDIA (marco organizativo, operacional y medidas de protección).
- Auditoría de seguridad obligatoria cada dos años, realizada por entidad certificadora acreditada (AENOR, Bureau Veritas, Adok, etc.).
- Obtención de Certificado de Conformidad ENS o Declaración de Conformidad, publicable en el directorio del CCN.
- Designación formal y documentada de las tres figuras de responsabilidad ENS.
- Elaboración y aprobación de una Política de Seguridad de la Información por la Corporación Municipal.

3. Infraestructura de Partida — GUARROMAN.LOCAL

A continuación se describe la infraestructura de sistemas de información existente, que constituye el objeto de análisis normativo del presente expediente. Esta infraestructura fue diseñada con criterios de segmentación por funciones, lo que representa una base positiva para el cumplimiento del ENS.

3.1 Sede Principal — Ayuntamiento de Guarromán

Segmento / VLAN	Red	Función	Sistemas
VLAN 2 — DMZ	10.1.2.0/24	Zona desmilitarizada	Apache2 + WordPress (con vulnerabilidades intencionadas para el CTF)
VLAN 3 — AD	10.1.3.0/24	Active Directory	Windows Server 2016 — Dominio GUARROMAN.LOCAL
VLAN 4 — SOC	10.1.4.0/24	Centro de Operaciones	Wazuh SIEM + Suricata IDS/IPS
VLAN 5 — Trabajo	10.1.5.0/24	Equipos de usuarios	Puestos de trabajo Windows
VLAN 6 — Trabajo	10.1.6.0/24	Equipos de usuarios	Puestos de trabajo Windows
WiFi	10.1.99.0/24	Red inalámbrica	Equipos Windows — SIN VLAN asignada (brecha crítica)
Router JSBach	172.29.230.160	Perímetro / Gateway	Linux — iptables, WireGuard VPN, gestión de VLANs

3.2 Sede Secundaria — Casa de la Cultura

Segmento / VLAN	Red	Función	Nota
VLAN 15	10.2.15.0/24	Trabajo CC	Equipos de trabajo Casa de la Cultura
VLAN 16	10.2.16.0/24	Trabajo CC	Equipos de trabajo Casa de la Cultura
WiFi CC	10.2.99.0/24	Red inalámbrica CC	Red independiente
VPN WireGuard	10.200.0.1	Interconexión sedes	Acceso al AD del Ayuntamiento desde CC mediante túnel cifrado

La interconexión entre sedes mediante VPN WireGuard con cifrado de 256 bits es una medida alineada con el control mp.com.2 del ENS (protección de la confidencialidad en comunicaciones). No obstante, el tráfico permitido a través del túnel debe limitarse estrictamente a los puertos necesarios para el acceso al Active Directory (88, 389, 445, 636).

4. Estado de Cumplimiento ENS — Blue Team Implementado

Se evalúa el cumplimiento actual de los controles del Anexo II del ENS para categoría MEDIA, tomando como referencia las medidas de bastionado ya implementadas por el equipo técnico. Los controles se agrupan en las tres familias definidas por el ENS: marco organizativo, marco operacional y medidas de protección.

Nota de alcance: El presente análisis se centra en los controles de mayor impacto técnico y operativo para la infraestructura de GUARROMAN.LOCAL. El Anexo II del RD 311/2022 contempla para categoría MEDIA un total de más de 50 controles agrupados en familias adicionales no desarrolladas en detalle en este expediente, entre las que destacan mp.if (protección física de instalaciones), mp.per (gestión del personal: formación, confidencialidad, acuerdos de uso), mp.eq (protección de equipos), mp.si (gestión de soportes de información) y op.ext (recursos externos y proveedores). La evaluación pormenorizada de estos controles, junto con la justificación formal de su aplicabilidad o no aplicabilidad, se recoge en la Declaración de Aplicabilidad, documento independiente que constituye el siguiente paso obligatorio en el proceso de adecuación al ENS y que deberá ser elaborado y firmado por el Responsable de Seguridad antes de la auditoría de certificación.

4.1 Marco Organizativo (org)

El marco organizativo recoge los controles relativos a la política de seguridad, normativa interna, procedimientos y procesos de autorización. Es el pilar sobre el que se sostiene todo el sistema de gestión de seguridad.

Control	Denominación	Estado actual	Nivel cumplimiento
org.1	Política de Seguridad de la Información	No existe documento formal aprobado por la Corporación Municipal.	Pendiente
org.2	Normativa de Seguridad	Sin normativa interna de uso aceptable de sistemas ni clasificación de información.	Pendiente
org.3	Procedimientos de Seguridad	Procedimientos técnicos existentes pero no formalizados documentalmente.	Pendiente
org.4	Proceso de Autorización	Sin proceso formal documentado de alta/baja/modificación de usuarios en AD.	Pendiente

4.2 Marco Operacional (op)

Control	Denominación	Estado actual	Nivel cumplimiento
op.pl.1	Análisis de riesgos	IMPLEMENTADO. Realizado y documentado en el informe técnico del proyecto. Identifica 8 riesgos con criticidad asignada.	Implementado
op.pl.2	Arquitectura de seguridad	IMPLEMENTADO. Documentada: VLANs por función, VPN entre sedes, DMZ aislada, SOC dedicado.	Implementado
op.acc.1	Control de acceso — política	Sin política formal de mínimo privilegio. AD operativo pero sin revisión periódica de cuentas.	Pendiente
op.acc.6	Mecanismo de autenticación	Autenticación por contraseña en AD. Sin MFA en accesos privilegiados ni en VPN. SSH con clave pública y sin acceso root implementados en JSBach.	En curso
op.exp.2	Configuración de seguridad	IMPLEMENTADO en JSBach: política DROP en FORWARD, rp_filter=1 anti-spoofing, puerto SSH no estándar, PermitRootLogin deshabilitado. Pendiente: credenciales por defecto en switches (R08).	En curso

Control	Denominación	Estado actual	Nivel cumplimiento
op.exp.4	Mantenimiento	Windows Server 2016 sin parcheado regular documentado (R03). Pendiente de subsanar.	Pendiente
op.exp.9	Registro de actividad	Wazuh SIEM operativo en VLAN 4 con FIM, Vulnerability Detector y Log Analysis activos. Alertas configuradas para login fallidos, cambios en ficheros críticos y escalada de privilegios. Agente pendiente en DMZ y endpoints.	En curso
op.mon.1	Detección de intrusión	Suricata operativo con regla custom para detección de escaneos Nmap. Pendiente: cambio a modo IPS bloqueante y alerta tráfico WiFi→VLANs (R04).	En curso
op.cont.1	Análisis de impacto (BIA)	No realizado. Sin Plan de Continuidad de Negocio documentado.	Pendiente
op.cont.2	Plan de continuidad	No existe. Sin procedimientos de recuperación ante incidentes graves.	Pendiente

4.3 Medidas de Protección (mp)

Control	Denominación	Estado actual	Nivel cumplimiento
mp.com.1	Perímetro seguro	IMPLEMENTADO parcialmente. JSBach con iptables, política DROP en FORWARD y rp_filter=1 anti-spoofing. Pendiente: aislamiento completo WiFi con VLAN 99 — riesgo CRÍTICO R01.	En curso
mp.com.2	Confidencialidad en comunicaciones	IMPLEMENTADO. VPN WireGuard 256 bits operativa, peers restringidos por IP de origen. Pendiente: documentar rotación de claves cada 90 días.	En curso
mp.sw.1	Protección de aplicaciones web	IMPLEMENTADO parcialmente. Logs Apache a Wazuh en tiempo real y fail2ban activo en Apache. Pendiente: ModSecurity WAF, deshabilitar directory listing y cambiar prefijo tablas WordPress.	En curso
mp.info.3	Calificación de la información	Sin política de clasificación de información ni Registro de Actividades de Tratamiento (RAT) RGD.	Pendiente
mp.info.9	Copias de seguridad	Sin política de backup documentada ni probada. Brecha crítica desde perspectiva ENS y continuidad.	Pendiente
mp.s.1	Protección de servicios web	IMPLEMENTADO parcialmente. Fail2ban activo en Apache. Pendiente: instalación de ModSecurity (WAF) en Apache2.	En curso

5. Brechas de Cumplimiento — Tareas Pendientes de Implementación

Las siguientes brechas han sido identificadas partiendo de la infraestructura existente de GUARROMAN.LOCAL. Constituyen incumplimientos normativos concretos del ENS categoría MEDIA y/o del RGPD que deben ser subsanados según el plan de implementación del apartado 6.

Los ítems marcados con $\triangle$ corresponden a elementos identificados en el plan de bastionado original del proyecto como pendientes de ejecución.

5.1 Brechas Críticas — Riesgo Inmediato

ID	Brecha	Control ENS incumplido	Riesgo asociado	Plazo
B01	$\triangle$ WiFi 10.1.99.0/24 sin VLAN ni aislamiento. Un equipo comprometido en WiFi tiene visibilidad directa al router JSBach y a todas las VLANs internas.	mp.com.1 / op.acc	CRÍTICO — R01	Inmediato
B02	Sin autenticación multifactor (MFA) en accesos privilegiados al AD y en acceso SSH al router JSBach.	op.acc.6	CRÍTICO	Inmediato
B03	Sin política de copias de seguridad documentada ni probada. Ante un incidente grave no existe garantía de recuperación.	mp.info.9 / op.cont	CRÍTICO	Inmediato

5.2 Brechas Altas — Resolución antes del CTF

ID	Brecha	Control ENS incumplido	Riesgo asociado	Plazo
B04	$\triangle$ Suricata en modo IDS (solo alertas, no bloquea). El tráfico malicioso detectado no es cortado activamente.	op.mon.1	ALTO — R04	Inmediato
B05	DMZ puede iniciar conexiones hacia VLANs internas. Un compromiso del servidor web permitiría lateral movement.	mp.com.1	ALTO — R02	Inmediato
B06	Windows Server 2016 sin parcheado regular. Vulnerable a ataques Kerberoasting y Pass-the-Hash (R03).	op.exp.4	ALTO — R03	Inmediato
B07	$\triangle$ Agente Wazuh no instalado en servidor Apache/WordPress (DMZ). Sin monitorización de integridad de ficheros (FIM).	op.exp.9	ALTO — R06	Inmediato
B08	$\triangle$ ModSecurity (WAF) no instalado en Apache2. Sin protección contra SQLi, XSS, LFI.	mp.s.1 / mp.sw.1	ALTO — R02	Inmediato
B09	Credenciales por defecto en switches SW1 y SW2. Acceso no autorizado a la gestión de red.	op.exp.2	ALTO — R08	Inmediato
B10	Sin Política de Seguridad de la Información aprobada formalmente por la Corporación Municipal.	org.1	ALTO	30 días

5.3 Brechas Medias — Resolución a Corto Plazo

ID	Brecha	Control ENS incumplido	Riesgo asociado	Plazo
B11	⚠ Directory listing habilitado en Apache (Options Indexes). Exposición de estructura de directorios.	mp.sw.1	MEDIO — R02	Inmediato
B12	⚠ Prefijo de tablas WordPress wp_ sin cambiar. Facilita ataques de inyección SQL dirigidos.	mp.sw.1	MEDIO — R02	30 días
B13	⚠ VLAN específica para WiFi (VLAN 99) no creada formalmente en el switch.	mp.com.1	MEDIO — R01	Inmediato
B14	Agentes Wazuh no desplegados en todos los endpoints de VLANs 5 y 6. Puntos ciegos en monitorización.	op.exp.9	MEDIO — R06	30 días
B15	Rotación de claves WireGuard no documentada ni planificada (cada 90 días).	mp.com.2	MEDIO — R05	30 días
B16	Switches SW1 y SW2 sin autenticación 802.1X. Riesgo de VLAN hopping.	op.acc / op.exp.2	MEDIO — R07	30 días
B17	Sin auditoría de eventos AD enviada a Wazuh. Sin correlación de eventos de red con eventos de host.	op.exp.9	MEDIO	30 días
B18	Sin Registro de Actividades de Tratamiento (RAT) — obligatorio RGPD Art. 30.	mp.info.3 / RGPD	MEDIO	30 días

5.4 Brechas Organizativas — Marco Documental

ID	Brecha	Control ENS incumplido	Plazo
B19	Sin normativa de uso aceptable de sistemas para empleados municipales.	org.2	90 días
B20	Sin procedimientos formalizados de gestión de incidentes de seguridad.	org.3 / op.exp.7	90 días
B21	Sin proceso formal de alta/baja/modificación de usuarios en el AD.	org.4	90 días
B22	Sin Plan de Continuidad de Negocio (BCP) ni Análisis de Impacto (BIA).	op.cont.1/2	90 días
B23	Sin Evaluación de Impacto en Protección de Datos (EIPD) para tratamientos de riesgo.	RGPD Art. 35	90 días

6. Plan de Implementación — Plazos y Responsables

El plan de implementación se estructura en cuatro bloques: medidas ya implementadas que acreditan cumplimiento parcial, y tres fases de trabajo pendiente ordenadas por urgencia. Dejar constancia de lo ya realizado es parte esencial de un expediente normativo, ya que evidencia el esfuerzo de adecuación en curso.

Bloque 0 — Medidas Ya Implementadas (acreditan cumplimiento parcial ENS)

Las siguientes medidas han sido implementadas por el equipo técnico y contribuyen al cumplimiento de los controles ENS indicados. Quedan registradas en este expediente como evidencia del trabajo realizado.

#	Medida implementada	Control ENS acreditado	Responsable
I-01	Política DROP en FORWARD en JSBach (iptables). Ningún tráfico no autorizado se reenvía entre interfaces.	mp.com.1	Quique Cebrián
I-02	rp_filter=1 activado en todas las interfaces de JSBach. Prevención de IP spoofing.	op.exp.2	Quique Cebrián
I-03	Puerto SSH no estándar, acceso solo por clave pública, PermitRootLogin deshabilitado en JSBach.	op.acc.6	Quique Cebrián
I-04	fail2ban configurado en JSBach para protección del acceso SSH.	op.exp.2	Quique Cebrián
I-05	VPN WireGuard 256 bits operativa entre sedes. Peers restringidos por IP de origen. Tráfico limitado a puertos AD (88, 389, 445, 636).	mp.com.2	Quique Cebrián
I-06	SMBv1 deshabilitado en Windows Server 2016 (protección frente a EternalBlue).	op.exp.2	Quique Cebrián
I-07	Windows Defender activo y actualizado en el servidor AD.	op.exp.4	Quique Cebrián
I-08	Política de contraseñas AD: mínimo 12 caracteres, complejidad, caducidad 90 días.	op.acc.6	Quique Cebrián
I-09	Fine-Grained Password Policy configurada para cuentas de administrador.	op.acc.6	Quique Cebrián
I-10	Protected Users Security Group configurado para cuentas privilegiadas.	op.acc.6	Quique Cebrián
I-11	AES256 activado para tickets Kerberos. RC4 deshabilitado (anti-Kerberoasting).	op.acc.6	Quique Cebrián
I-12	Domain Admins limitados al mínimo necesario (principio de mínimo privilegio).	op.acc.1	Quique Cebrián
I-13	Auditoría de eventos AD habilitada: inicio de sesión, cambios en cuentas, acceso a objetos.	op.exp.9	Quique Cebrián
I-14	Wazuh SIEM operativo en VLAN 4 con módulos FIM, Vulnerability Detector y Log Analysis activos.	op.exp.9	Quique Cebrián
I-15	Alertas Wazuh configuradas: login fallidos >5 en 1 min, cambios en ficheros críticos, escalada de privilegios.	op.exp.9	Quique Cebrián
I-16	Suricata operativo. Regla custom para detección de escaneos Nmap contra la red interna.	op.mon.1	Quique Cebrián

#	Medida implementada	Control ENS acreditado	Responsable
I-17	Logs de Apache enviados a Wazuh en tiempo real.	op.exp.9	Quique Cebrián
I-18	fail2ban configurado en el servidor Apache para bloqueo de IPs con fuerza bruta.	op.exp.2	Quique Cebrián
I-19	Equipos de usuarios unidos al dominio GUARROMAN.LOCAL.	op.acc	Quique Cebrián
I-20	GPO de seguridad aplicadas en endpoints: USB deshabilitado, firewall Windows activo, PowerShell no firmado bloqueado.	op.exp.2	Quique Cebrián

Fase 1 — Inmediato (antes del ejercicio CTF)

#	Acción pendiente	Brecha que cierra	Control ENS	Responsable
1	Aislar WiFi (10.1.99.0/24) con VLAN 99 y reglas iptables en JSBach	B01, B13	mp.com.1	Quique Cebrián
2	Cambiar Suricata de modo IDS a modo IPS bloqueante	B04	op.mon.1	Quique Cebrián
3	Instalar agente Wazuh en Apache2/WordPress (DMZ) — activar FIM	B07	op.exp.9	Quique Cebrián
4	Aplicar regla iptables: DMZ no puede iniciar conexiones a VLANs internas	B05	mp.com.1	Quique Cebrián
5	Parchear Windows Server 2016 — aplicar todos los updates disponibles	B06	op.exp.4	Quique Cebrián
6	Instalar ModSecurity (WAF) en Apache2	B08	mp.s.1	Quique Cebrián
7	Cambiar credenciales por defecto en switches SW1 y SW2	B09	op.exp.2	Quique Cebrián
8	Deshabilitar directory listing en Apache (Options -Indexes)	B11	mp.sw.1	Quique Cebrián
9	Crear alerta Suricata para tráfico desde WiFi (10.1.99.0/24) hacia VLANs internas	B04	op.mon.1	Quique Cebrián

Fase 2 — Corto plazo (30 días)

#	Acción pendiente	Brecha que cierra	Control ENS	Responsable
10	Instalar agentes Wazuh en todos los endpoints (VLANs 5 y 6)	B14	op.exp.9	Quique Cebrián
11	Activar 802.1X en switches SW1 y SW2	B16	op.acc	Quique Cebrián
12	Documentar y planificar rotación de claves WireGuard (cada 90 días)	B15	mp.com.2	Quique Cebrián
13	Cambiar prefijo de tablas WordPress (wp_ por valor aleatorio)	B12	mp.sw.1	Quique Cebrián
14	Elaborar y aprobar Política de Seguridad de la Información	B10	org.1	Quique Cebrián + Alcalde

#	Acción pendiente	Brecha que cierra	Control ENS	Responsable
15	Elaborar Registro de Actividades de Tratamiento (RAT) — RGPD Art. 30	B18	mp.info.3	Quique Cebrián
16	Implementar política de copias de seguridad 3-2-1 con prueba de restauración	B03	mp.info.9	Quique Cebrián
17	Implementar MFA en accesos privilegiados AD y en VPN	B02	op.acc.6	Quique Cebrián

Fase 3 — Medio plazo (90 días)

#	Acción pendiente	Brecha que cierra	Control ENS	Responsable
18	Elaborar normativa de uso aceptable de sistemas para empleados municipales	B19	org.2	Quique Cebrián + Alcalde
19	Formalizar procedimientos de gestión de incidentes de seguridad	—	org.3	Quique Cebrián
20	Implementar proceso formal de alta/baja/modificación de usuarios en AD	B20	org.4	Quique Cebrián
21	Realizar Análisis de Impacto (BIA) y elaborar Plan de Continuidad (BCP)	B21	op.cont.1/2	Quique Cebrián + Alcalde
22	Realizar Evaluación de Impacto en Protección de Datos (EIPD)	B22	RGPD Art. 35	Quique Cebrián
23	Actualizar WordPress y eliminar plugins y temas no usados	—	mp.sw.1	Quique Cebrián
24	Solicitar auditoría externa ENS categoría MEDIA a entidad acreditada (AENOR, Bureau Veritas, Adok)	—	Art. 31 RD311/2022	Alcalde

7. Resumen Ejecutivo

El Ayuntamiento de Guarromán, en su condición de Administración Local, tiene la obligación legal de adecuar sus sistemas de información al Esquema Nacional de Seguridad conforme al Real Decreto 311/2022. La categorización de sus sistemas corresponde a CATEGORÍA MEDIA, lo que determina el conjunto de medidas exigibles y los mecanismos de conformidad aplicables.

Trabajo ya realizado — Base sólida de cumplimiento

El equipo técnico ha implementado un total de 20 medidas de seguridad que acreditan cumplimiento parcial del ENS y reflejan un enfoque correcto de defensa en profundidad. Entre las más relevantes destacan: la política de mínimo privilegio en el Active Directory, la protección Kerberos con AES256 y Protected Users Group, el SOC operativo con Wazuh y Suricata, la VPN WireGuard cifrada entre sedes, y el hardening completo del router JSBach. Esta base técnica es el punto de partida del proceso de adecuación, no el punto de llegada.

Brechas abiertas — Lo que resta por implementar

A pesar del trabajo realizado, persisten brechas que impiden declarar la conformidad con el ENS en este momento. Las más graves son: el aislamiento incompleto de la red WiFi (riesgo crítico que expone toda la infraestructura), la ausencia de copias de seguridad documentadas y probadas, y la carencia del marco documental organizativo obligatorio (Política de Seguridad, normativa interna, procedimientos formales). Estas brechas deben resolverse según el calendario del plan de implementación.

Próximos pasos

- Completar las 9 acciones de la Fase 1 antes del ejercicio CTF para cerrar las brechas de mayor riesgo operativo.
- Completar el marco documental y técnico en los 30 días siguientes (Fase 2), con especial atención a la Política de Seguridad y el RAT del RGPD.
- Completar el plan de adecuación en los 90 días siguientes (Fase 3) y solicitar auditoría externa para obtener la certificación ENS categoría MEDIA.

Anexo A — Guía de Normativa para Personal No Técnico del Ayuntamiento

Este anexo está dirigido al personal del Ayuntamiento sin formación técnica en informática: Alcalde, Concejales, personal administrativo. Su objetivo es explicar de forma sencilla qué obliga la ley y por qué es importante cumplirla.

¿Qué es el ENS y por qué nos afecta?

El Esquema Nacional de Seguridad (ENS) es una ley española que obliga a todos los ayuntamientos y administraciones públicas a proteger adecuadamente sus sistemas informáticos y los datos que manejan. No es opcional: su incumplimiento puede acarrear responsabilidades administrativas y dificultar la relación con otras administraciones.

Piénselo así: igual que un edificio público debe cumplir normas de seguridad contra incendios para proteger a las personas, los sistemas informáticos del Ayuntamiento deben cumplir normas de ciberseguridad para proteger los datos de los ciudadanos y garantizar que los servicios municipales funcionen correctamente.

¿Qué es el RGPD y qué tiene que ver con nosotros?

El Reglamento General de Protección de Datos es una ley europea que protege la información personal de los ciudadanos. El Ayuntamiento maneja datos muy sensibles: el padrón municipal, expedientes de servicios sociales, datos fiscales, licencias. Si esos datos se pierden, se roban o se usan sin autorización, el Ayuntamiento puede ser sancionado por la Agencia Española de Protección de Datos (AEPD) con multas significativas.

¿Qué significan los controles org.1, org.2, org.3 y org.4?

Estos cuatro controles son los que el ENS llama 'marco organizativo'. Son los más importantes porque sin ellos todo lo demás no sirve de nada. En lenguaje sencillo significan:

Control	Nombre técnico	Qué significa en la práctica
org.1	Política de Seguridad	El Ayuntamiento debe tener un documento oficial, aprobado por el Pleno, que diga cómo se va a proteger la información. Es como el reglamento de seguridad de la empresa: sin él, nadie sabe qué reglas seguir.
org.2	Normativa de Seguridad	Las normas concretas que deben seguir todos los empleados: cómo usar el ordenador, qué está permitido y qué no, cómo crear contraseñas seguras, qué hacer si se pierde un dispositivo. Sin estas normas los empleados no saben cómo comportarse.
org.3	Procedimientos de Seguridad	Los pasos exactos a seguir cuando ocurre algo: ¿qué hacemos si nos hackean? ¿quién llama a quién? ¿cómo recuperamos los datos? Es como el protocolo de emergencias, pero para incidentes informáticos.
org.4	Proceso de Autorización	El procedimiento formal para dar acceso a los sistemas a un empleado nuevo y para quitárselo cuando se va. Sin esto, ex-empleados pueden seguir accediendo a los sistemas del Ayuntamiento sin que nadie lo sepa.

¿Por qué es tan grave que la WiFi no esté aislada?

Imagine que el Ayuntamiento tiene una sala de reuniones con WiFi para visitas. Si esa red WiFi está conectada directamente a los mismos sistemas que usan los funcionarios, cualquier persona que se conecte a esa WiFi (o que infecte un dispositivo conectado a ella) podría acceder a los expedientes, al padrón o a los sistemas

de contabilidad del Ayuntamiento. Es como si la puerta de la sala de reuniones diera directamente al despacho del Alcalde sin ninguna cerradura entre medias.

¿Qué pasa si no cumplimos?

- Sanciones económicas de la AEPD por incumplimiento del RGPD en caso de brecha de datos personales.
- Responsabilidad administrativa de los cargos electos y técnicos municipales por incumplimiento del ENS.
- Imposibilidad de acreditar el cumplimiento ante otras administraciones o para acceder a determinadas financiaciones.
- Daño reputacional ante los ciudadanos si se produce un incidente de seguridad que afecte a sus datos.

¿Qué necesitamos que haga la Corporación Municipal?

El técnico de sistemas puede implementar todas las medidas técnicas, pero hay tres cosas que solo puede hacer la Corporación Municipal:

- Aprobar formalmente la Política de Seguridad de la Información en Pleno (org.1).
- Designar oficialmente las figuras de Responsable de la Información, del Sistema y de Seguridad.
- Autorizar y financiar la auditoría externa de conformidad con el ENS, obligatoria cada dos años para sistemas de categoría Media.

Para cualquier consulta sobre el contenido técnico de este expediente, contactar con:

**Quique Cebrián — Técnico en Sistemas TI — Responsable de Seguridad del Sistema
GUARROMAN.LOCAL**

Anexo B — Compromiso de Confidencialidad y Protección de Datos

Ayuntamiento de Guarromán

En Guarromán, a ____ de _____ de 20__

D./Dña. _____, con DNI _____, en su condición de (funcionario de carrera / personal laboral / contratista / becario) adscrito al Ayuntamiento de Guarromán,

DECLARA Y SE COMPROMETE:

Primero. Que ha sido informado de que en el ejercicio de sus funciones tendrá acceso a información confidencial, datos personales de ciudadanos y datos de gestión administrativa del Ayuntamiento de Guarromán, protegidos por el Reglamento General de Protección de Datos (UE) 2016/679, la Ley Orgánica 3/2018 de Protección de Datos y Garantía de los Derechos Digitales, y el Esquema Nacional de Seguridad (RD 311/2022).

Segundo. Que se compromete a tratar la información a la que tenga acceso únicamente para el desempeño de las funciones propias de su puesto, y a no divulgarla, compartirla ni utilizarla para fines ajenos a su actividad profesional, ni durante su relación con el Ayuntamiento ni una vez finalizada esta.

Tercero. Que conoce y acepta la normativa de uso de los sistemas de información del Ayuntamiento de Guarromán, incluyendo las normas sobre contraseñas, uso de dispositivos, acceso remoto y gestión de soportes de información.

Cuarto. Que se compromete a comunicar de forma inmediata al Responsable de Seguridad cualquier incidente de seguridad, brecha de datos o uso indebido de la información del que tenga conocimiento.

Quinto. Que conoce que el incumplimiento de este compromiso podrá dar lugar a: responsabilidad disciplinaria conforme al Real Decreto Legislativo 5/2015 por el que se aprueba el Estatuto Básico del Empleado Público (EBEP); responsabilidad civil por los daños y perjuicios causados; y responsabilidad penal conforme a los artículos 197 y siguientes del Código Penal en caso de revelación o cesión de datos personales sin autorización.

Este compromiso tiene carácter indefinido y sus obligaciones se mantienen vigentes con posterioridad a la extinción de la relación profesional con el Ayuntamiento de Guarromán.

Fdo.: El/La empleado/a

Nombre: _____

DNI: _____

Firma: _____

Fdo.: El Alcalde del Ayuntamiento de Guarromán

Firma: _____

Anexo C — Plan de Concienciación en Seguridad de la Información

Ayuntamiento de Guarromán

1. Objeto

El presente plan tiene por objeto garantizar que todo el personal del Ayuntamiento de Guarromán, con independencia de su categoría o tipo de relación laboral, conozca sus obligaciones en materia de seguridad de la información y protección de datos personales, y disponga de los conocimientos mínimos necesarios para no comprometer la seguridad de los sistemas de información municipales. Este plan responde al cumplimiento del control mp.per.3 del Anexo II del ENS (RD 311/2022) y al principio de concienciación continua establecido en las políticas de seguridad de las Administraciones Públicas.

2. Ámbito de Aplicación

El plan es de aplicación obligatoria para todo el personal del Ayuntamiento de Guarromán: funcionarios de carrera, personal laboral, personal interino, eventuales, contratistas externos con acceso a sistemas municipales y becarios o personal en prácticas.

3. Responsable

Quique Cebrián, Técnico en Sistemas TI y Responsable de Seguridad del sistema GUARROMAN.LOCAL, es el responsable de planificar, ejecutar y registrar todas las acciones de este plan.

4. Acciones del Plan

Acción 1. Sesión de incorporación para nuevos empleados

Todo empleado que acceda por primera vez a los sistemas de información del Ayuntamiento recibirá una sesión formativa antes de obtener sus credenciales de acceso. Duración mínima: 1 hora. Contenido: obligaciones legales del empleado público en materia de seguridad y protección de datos, normas de uso de los sistemas de información de GUARROMAN.LOCAL, política de contraseñas, uso correcto de dispositivos y correo electrónico, y qué hacer ante un incidente de seguridad. Al finalizar, el empleado firmará el Compromiso de Confidencialidad (Anexo B).

Acción 2. Formación anual obligatoria

Una vez al año se realizará una sesión de formación en seguridad de la información dirigida a todo el personal. Duración mínima: 2 horas. El contenido se actualizará cada año en función de los incidentes ocurridos, nuevas amenazas identificadas o cambios normativos. Se utilizarán materiales gratuitos del CCN-CERT disponibles en el portal INES y las guías CCN-STIC aplicables. La asistencia es obligatoria y quedará registrada con firma del empleado.

Acción 3. Comunicaciones periódicas de concienciación

El Responsable de Seguridad enviará mensualmente un mensaje breve por correo electrónico interno con un recordatorio o alerta concreta en materia de seguridad. Ejemplos: cómo identificar un correo de phishing, qué hacer si se pierde un dispositivo municipal, por qué no se deben usar USBs de origen desconocido, importancia de bloquear el equipo al ausentarse del puesto.

Acción 4. Cartelera informativa

Se colocarán carteles en las zonas de trabajo con los mensajes clave de seguridad: no compartir contraseñas, bloquear el equipo al salir, no conectar dispositivos no autorizados, a quién llamar en caso de incidente. El contenido se renovará al menos una vez al año.

5. Registro y Evidencia

Cada acción formativa quedará registrada en un acta o registro de asistencia firmado por los participantes. Este registro se conservará como evidencia de cumplimiento del control mp.per.3 del ENS y estará disponible para la auditoría de certificación.

Anexo D — Sistema Interno de Información y Canal de Denuncias

Ayuntamiento de Guarromán

1. Base Legal y Obligatoriedad

El Ayuntamiento de Guarromán está obligado a disponer de un Sistema Interno de Información conforme a la Ley 2/2023, de 20 de febrero, reguladora de la protección de las personas que informen sobre infracciones normativas y de lucha contra la corrupción. Esta obligación afecta a todas las entidades del sector público, incluyendo la Administración Local, con independencia de su tamaño. El plazo máximo para su implantación venció el 1 de diciembre de 2023. La no implantación constituye una infracción administrativa grave.

2. Objeto

El Sistema Interno de Información permite a cualquier persona, en el contexto de su relación profesional con el Ayuntamiento, comunicar de forma confidencial o anónima posibles infracciones del ordenamiento jurídico, incumplimientos de la normativa de protección de datos, vulneraciones de la normativa de seguridad de la información o cualquier conducta contraria a la integridad en el ejercicio de la función pública municipal.

3. Quién Puede Utilizar Este Canal

Pueden utilizar este canal: funcionarios de carrera, personal laboral, personal interino y eventual, contratistas y proveedores con relación profesional con el Ayuntamiento, becarios y personal en prácticas, y cualquier persona que en el ejercicio de su actividad profesional haya tenido conocimiento de una infracción en el ámbito municipal.

4. Qué Se Puede Comunicar

Cualquier acción u omisión que pueda constituir una infracción del ordenamiento jurídico español o del Derecho de la Unión Europea, en particular: incumplimientos de la normativa de protección de datos (RGPD, LOPDGDD), vulneraciones de la política de seguridad de la información y del ENS, uso indebido de datos personales de ciudadanos o empleados, acceso no autorizado a sistemas o información municipal, y conductas contrarias a la integridad, la transparencia o la buena gestión de los recursos públicos. Este canal no es el adecuado para quejas, sugerencias o conflictos laborales ordinarios.

5. Cómo Funciona el Canal

El canal admite comunicaciones identificadas y anónimas. Nadie está obligado a identificarse. En caso de comunicación anónima se garantiza igualmente la tramitación de la denuncia si contiene indicios razonables.

Vías de comunicación: correo electrónico a la dirección exclusiva denuncias@guarroman.es, accesible únicamente por el Responsable del Sistema; o mediante escrito en sobre cerrado dirigido al Alcalde con la indicación Confidencial — Sistema Interno de Información.

Plazos: acuse de recibo en un plazo máximo de 7 días hábiles desde la recepción. Investigación y resolución en un plazo máximo de 3 meses, prorrogable motivadamente.

6. Responsable del Sistema

El Responsable del Sistema Interno de Información es el Alcalde del Ayuntamiento de Guarromán, quien actúa con plena independencia en la gestión de las comunicaciones recibidas. En caso de que la denuncia afecte al propio Alcalde, el canal externo disponible es la Diputación Provincial de Jaén o la Autoridad Independiente de Protección del Informante (AIPI) a nivel estatal.

7. Protección del Informante

El Ayuntamiento de Guarromán garantiza expresamente que ninguna persona que utilice este canal de buena fe y con indicios razonables sufrirá represalias de ningún tipo: ni despido, ni sanciones disciplinarias, ni cambio de condiciones laborales, ni ninguna otra medida perjudicial derivada de haber presentado una comunicación. Esta protección se extiende también a los testigos y personas del entorno del informante. Las comunicaciones falsas o realizadas con mala fe no estarán amparadas por esta protección y podrán dar lugar a las responsabilidades que procedan.

8. Confidencialidad y Protección de Datos

La identidad del informante y de cualquier tercero mencionado en la comunicación es estrictamente confidencial. Los datos personales relacionados con las comunicaciones e investigaciones se conservarán únicamente durante el tiempo necesario, con un máximo de 10 años, y no serán accesibles más que al Responsable del Sistema y, en su caso, a jueces y tribunales en el marco de un procedimiento judicial.

9. Nota sobre Municipios Pequeños

La Ley 2/2023 permite que los municipios de menos de 10.000 habitantes compartan el Sistema Interno de Información con la Diputación Provincial de adscripción. El Ayuntamiento de Guarromán valorará la adhesión al sistema de la Diputación Provincial de Jaén como alternativa complementaria que refuerce la independencia y los recursos disponibles para la investigación de comunicaciones.